

1. Introduction

This Security Requirements Document defines the main security requirements for the Secure Inventory Management Platform. The purpose of the platform is to manage inventory items, stock quantities, suppliers, purchase/order records, users, roles, reports, and audit logs in a secure manner.

The SRD focuses on the security controls required during Phase 1 of the project. It supports threat modelling activities by identifying assets, roles, assumptions, security objectives, and prioritized security requirements for the system.

1.1 Purpose

The purpose of this document is to define clear and testable security requirements for the platform before implementation. These requirements help protect confidentiality, integrity, and availability of inventory and business data.

1.2 Scope

The scope of this SRD includes authentication, access control, inventory data protection, supplier/order data protection, input validation, API security, encryption, logging, monitoring, backup, recovery, and security testing. Docker, Kubernetes, CI/CD, and monitoring implementation details will be handled in later phases, but security requirements are identified here to guide future work.

2. System Context

2.1 Main Users and Roles

Role	Description
Admin	Manages users, roles, permissions, system security settings, audit logs, and security events.
Inventory Manager	Manage inventory items, stock quantities, suppliers, purchase/order records, and inventory reports.
Staff/User	Performs limited inventory operations such as viewing assigned stock records and updating permitted stock information.
Auditor	Reviews inventory reports, audit logs, stock changes, and security-related activity records.

2.2 Critical Assets

Asset	Security Importance
User accounts and credentials	Must be protected from unauthorized access and account takeover.
Inventory records	Must be protected from unauthorized modification, deletion, and fake stock entries.
Supplier records	Must be protected from data leakage and unauthorized changes.
Purchase/order records	Must be protected to prevent fraud and incorrect business decisions.
Authentication/session tokens	Must be protected from theft, reuse, and session hijacking.

Audit logs	Must be protected from tampering so user actions remain traceable.
Database	Must be protected because it stores the main system data.

3. Assumptions and Dependencies

Type	Statement
Assumption	The system is a web-based application accessed through a browser by authenticated users.
Assumption	Inventory operations are performed through backend APIs and protected by server-side authorization checks.
Assumption	The database is hosted inside an internal network boundary or protected cloud network.
Dependency	The system depends on a backend API framework, database, authentication/session mechanism, logging storage, and network infrastructure.
Dependency	Later phases may add Docker, Kubernetes, CI/CD, runtime monitoring, and SIEM integrations.

4. Security Objectives

- Protect user accounts, passwords, and session tokens from compromise.
- Ensure only authorized users can access inventory, supplier, order, report, and audit functions.
- Prevent unauthorized stock modification, fake inventory entries, and record tampering.
- Protect sensitive inventory, supplier, and order data from disclosure.
- Maintain accountability through audit logging and monitoring.
- Maintain system availability against API abuse, brute force attacks, and denial-of-service attempts.
- Ensure security requirements can be verified through review, testing, and threat modelling.

5. Security Requirements

The following 20 security requirements are prioritized for Phase 1. They are written to cover the main security risks identified for the Secure Inventory Management Platform while keeping the SRD concise and focused.

ID	Requirement	Description	Priority
SR-01	Secure Authentication	The system shall require valid credentials for every user login and shall reject unauthenticated access to protected pages and APIs.	High
SR-02	Strong Password Policy	The system shall enforce minimum password length, complexity rules, and secure password reset procedures.	High
SR-03	Multi-Factor Authentication for Privileged Roles	The system should support MFA for Admin and Inventory Manager accounts to reduce account takeover risk.	High
SR-04	Secure Session Management	The system shall use secure session or JWT handling with expiration, secure cookies, token validation, and logout support.	High
SR-05	Role-Based Access Control	The system shall enforce role-based access control for Admin, Inventory Manager, Staff/User, and Auditor roles.	High
SR-06	Least Privilege Access	The system shall allow users to access only the features and data required for their assigned role.	High
SR-07	Server-Side	The backend shall validate permissions on every sensitive	High

	Authorization Checks	request and shall not rely only on frontend button hiding or URL restrictions.	
SR-08	Secure Inventory Record Management	Only authorized users shall be able to create, update, delete, or view inventory records according to their assigned permissions.	High
SR-09	Stock Change Control	The system shall log every stock quantity change and should require approval for high-risk or unusual stock updates.	High
SR-10	Supplier and Order Data Protection	Supplier details and purchase/order records shall only be accessible to authorized users and shall be protected from unauthorized modification.	High
SR-11	Input Validation	The system shall validate all user input using allow-list rules, type checks, length checks, and business rules before processing.	High
SR-12	Injection Prevention	The system shall use prepared statements, ORM validation, and safe query handling to prevent SQL Injection and related injection attacks.	High
SR-13	Cross-Site Scripting Prevention	The system shall sanitize input and encode output for product names, supplier names, notes, reports, and other displayed fields.	High
SR-14	API Abuse and CSRF Protection	The system shall use rate limiting, throttling, anti-CSRF controls where applicable, and request origin validation for state-changing operations.	High
SR-15	Encryption in Transit	The system shall use HTTPS/TLS for all communication between users, application services, and databases where supported.	High
SR-16	Secure Storage of Sensitive Data	Passwords shall be hashed using a strong algorithm, and sensitive configuration values or secrets shall not be stored in plaintext.	High
SR-17	Audit Logging	The system shall record login attempts, failed logins, inventory changes, supplier/order changes, role changes, and report downloads.	High
SR-18	Security Monitoring and Alerts	The system shall detect suspicious activity such as repeated failed logins, unusual stock changes, and excessive API requests.	Medium
SR-19	Backup and Recovery	The system shall support secure backup and recovery of inventory records, supplier/order data, and audit logs.	Medium
SR-20	Security Verification	The system shall be reviewed and tested for authentication, access control, injection, XSS, API abuse, logging, and data protection issues.	High

6. Role-Based Access Matrix

Function	Admin	Inventory Manager	Staff/User	Auditor
Login	Allowed	Allowed	Allowed	Allowed
Manage Users	Allowed	Not Allowed	Not Allowed	Not Allowed
Manage Roles	Allowed	Not Allowed	Not Allowed	Not Allowed
Add Inventory Item	Allowed	Allowed	Not Allowed	View Only
Update Stock	Allowed	Allowed	Limited	View Only

Delete Inventory Item	Allowed	Allowed with approval	Not Allowed	View Only
Manage Suppliers	Allowed	Allowed	Not Allowed	View Only
Generate Reports	Allowed	Allowed	Limited	Allowed
View Audit Logs	Allowed	Limited	Not Allowed	Allowed
Monitor Security Events	Allowed	Limited	Not Allowed	View Only

7. Threat-to-Requirement Traceability

Threat Area	Mapped Requirements	Reason
Spoofing / account takeover	SR-01, SR-02, SR-03, SR-04	Strong authentication, MFA, password rules, and secure sessions reduce impersonation risk.
Privilege escalation	SR-05, SR-06, SR-07	RBAC, least privilege, and backend authorization checks prevent unauthorized privilege use.
Unauthorized stock modification	SR-08, SR-09, SR-17	Inventory permissions, stock change control, and audit logs protect record integrity.
Supplier/order data leakage	SR-05, SR-10, SR-15, SR-16	Access control, data protection, encryption, and secure storage protect sensitive business data.
SQL Injection / tampering	SR-11, SR-12, SR-20	Input validation, safe query handling, and testing reduce injection risks.
Cross-Site Scripting	SR-11, SR-13, SR-20	Input checks, output encoding, and verification reduce XSS risk.
API abuse / brute force / DoS	SR-14, SR-18, SR-19	Rate limiting, monitoring, and recovery controls improve availability.
Repudiation and log tampering	SR-17, SR-18, SR-19	Audit logs, monitoring, and backups preserve accountability and recovery evidence.

8. Acceptance Criteria

- Every protected API must reject unauthenticated requests.
- Every sensitive operation must verify the user role on the backend.
- Passwords must never be stored in plaintext.
- Inventory changes must be logged with user ID, timestamp, action, and affected record.
- Invalid or malicious input must be rejected or safely handled.
- Sensitive pages and APIs must use HTTPS in deployment.
- The system must provide evidence of security testing for major risks such as broken access control, SQL Injection, XSS, and API abuse.
- Backup and recovery procedures must be documented for inventory records and audit logs.

9. Security Constraints

- The system shall not expose stack traces, database error messages, or internal configuration details to users.

- The system shall not allow frontend-only authorization for protected functions.
- The system shall not allow direct database access from external users.
- The system shall not store credentials, tokens, or secrets in plaintext files or public repositories.
- The system shall not allow deletion or modification of audit logs by normal users.

10. Conclusion

This Security Requirements Document defines 20 prioritized requirements for the Secure Inventory Management Platform. The requirements cover authentication, authorization, inventory integrity, input validation, API protection, encryption, logging, monitoring, backup, recovery, and verification. These requirements will guide the threat model, risk matrix, framework mapping, and later implementation phases of the project.